

MONTHLY THREAT REPORT

APRIL

2026

CYBERSECURITY
LANDSCAPE ASSESSMENT

Executive Summary

The Misbar threat intelligence assessment for **April 2026** documents an inflection point in the year's ransomware trajectory. After March's record-setting **808 victims**, April pulled back modestly to **772 claimed victims**, but the underlying ecosystem expanded further, reaching **70 distinct active groups** across 79 countries. The slowdown in headline volume masks an accelerating fragmentation that defenders should not interpret as relief.

Two structural shifts defined the month. First, **Qilin** held the top spot for a fourth consecutive month with 103 victims, but with a much narrower lead, signaling that the operator concentration that defined late-2025 is finally giving way to a flatter, more competitive landscape. Second, **healthcare returned to the #1 targeted sector** with 64 victims, displacing manufacturing for the first time in 2026.

The standout incident vector of April was **third-party and supply-chain compromise**. The Vimeo breach via Anodot, the ADT extortion claim of 5.5 million records by ShinyHunters, the Vercel incident traced to Context.ai, and the Booking.com customer-data exposure all shared a common pattern: attackers reached primary brands by compromising trusted vendors, suppliers, or third-party integrations rather than the targets themselves.

The vulnerability landscape was dominated by Cisco. CISA's **Emergency Directive 26-03**, issued April 20, mandated 72-hour federal remediation of three Cisco Catalyst SD-WAN Manager flaws, two of which (**CVE-2026-20122** and **CVE-2026-20128**) Cisco confirmed as exploited in March. The directive marked the most aggressive federal patching mandate of 2026 to date.

This report consolidates April's most consequential signals into prioritized, actionable intelligence. Our assessment: the ecosystem is maturing toward sustained high-volume operations rather than declining. Defensive postures built on 2024-era assumptions will increasingly prove inadequate against an adversary economy now operating at industrial scale.

CONNECT WITH US

Stay updated with real-time alerts and upcoming technical deep-dives through our official channels:

X: @MisbarSec

WhatsApp Channel: <https://whatsapp.com/channel/0029Vb6BZRV84Om7iRZKwZ12>

Ransomware Landscape

April 2026 settled at **772 claimed victims**, a 4.5% decline from March's record but still well above Q1's flat baseline of ~680. Every month of 2026 has now exceeded any single month of 2025. The active operator population grew to **70 groups**, the highest count of the year, confirming that ecosystem fragmentation continues unabated.



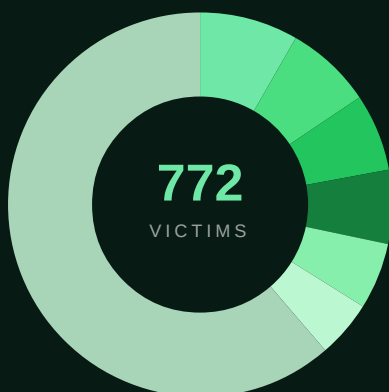
►2026 MONTHLY TRAJECTORY

April closes the first third of 2026 with cumulative victim counts running approximately **19% ahead** of the same period in 2025. The trajectory now annualizes to roughly 8,800 victims for the year, well above 2025's record of 7,308.



►SECTOR TARGETING

April produced the most significant sector shift of the year so far: **healthcare reclaimed the top position** with 64 victims, up from 47 in March, while manufacturing, previously the perennial #1, declined to 50. Technology jumped sharply to 56 victims, the sector's highest count of the year. The rotation suggests attacker economics, not defensive improvements, are driving the shift.

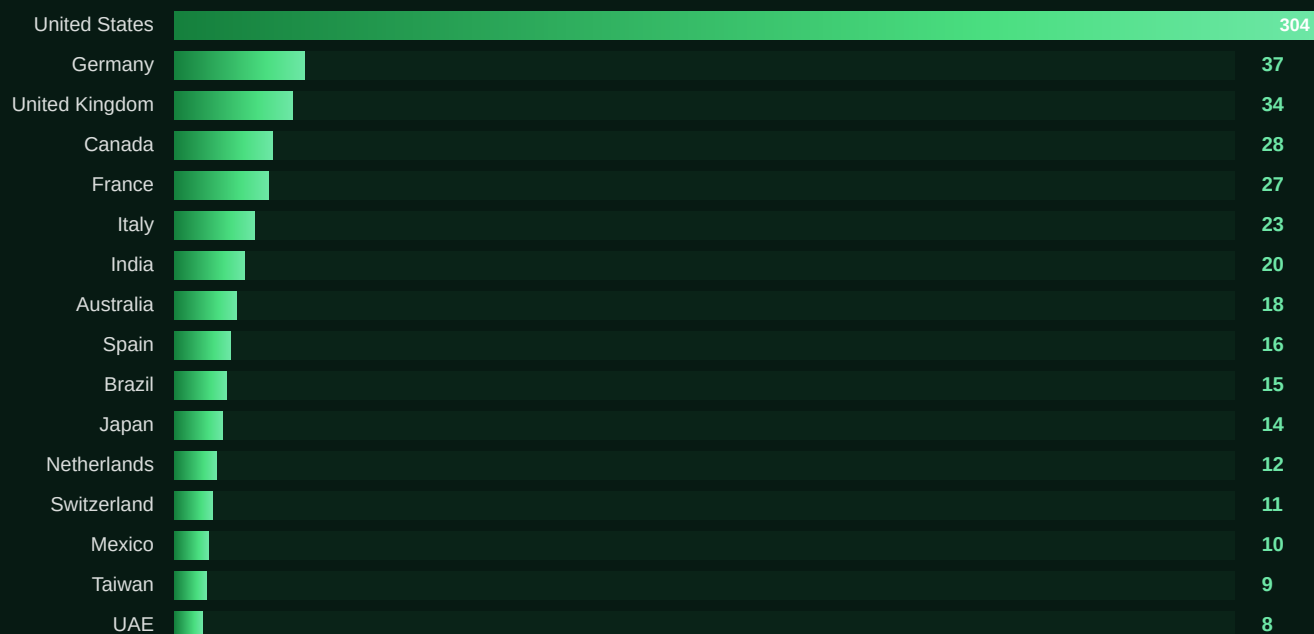


Healthcare	64	8.3%
Technology	56	7.3%
Manufacturing	50	6.5%
Construction	48	6.2%
Financial Services	43	5.6%
Business Services	37	4.8%
Others (long tail)	474	61.4%

April 2026 ransomware victims by sector

Geographic Distribution

April marked the most diversified geographic distribution of any 2026 month so far. The United States remained the dominant target with **304 victims**, but its share declined from March's 50% to **39%**, the lowest of the year. Germany rose to second place with 37 victims, the UK to third with 34, and **Canada recorded its largest month-over-month jump** of the year, reaching 28 victims.



Geographic distribution of observed ransomware victims, April 2026

►GEOGRAPHIC SIGNALS

The European cluster, Germany, UK, France, Italy, Netherlands, Switzerland, collectively absorbed approximately 144 victims, surpassing the combined total of Asia-Pacific markets for the first time in 2026. The **79 countries** hit during the month (up from 75 in March) confirms that opportunistic targeting now reaches genuinely global scope, with single-victim incidents distributed across the long tail.

Canadian surge: April's spike from 17 to 28 victims is the largest month-over-month jump among top-tier targets. Several Canadian incidents traced to the same affiliate network suggest opportunistic exploitation of perimeter VPN and RMM exposures rather than country-targeted campaigns.

Most Active Operators

April's operator landscape showed continued concentration at the top combined with growing competition. Qilin held the leading position for a fourth consecutive month, but with its narrowest margin yet, while TheGentlemen continued its steady scaling and DragonForce climbed into firm third place. The top ten captured roughly two-thirds of total volume, leaving 60 smaller groups to share the remainder.

Qilin 103 victims -28 vs March RaaS · double extortion · 4-month leader. Affiliate network shrinking but still dominant.	01	TheGentlemen 82 victims +18 vs March SystemBC + Mimikatz tradecraft. Now using Group Policy lateral movement.	02
DragonForce 63 victims +9 vs March Climbing aggressively · absorbed RansomHub affiliates after April infrastructure takeover.	03	Akira 54 victims -30 vs March Established RaaS. SonicWall VPN exploit utility now declining.	04
Play 38 victims +2 vs March FBI tracks ~900+ victims to date. Credential-based access · long dwell.	05	Medusa 31 victims +7 vs March Persistent healthcare focus · opportunistic US targeting.	06
NightSpire 28 victims -20 vs March In-house ops (no RaaS). Manufacturing + tech + construction focus.	07	Brain Cipher 22 victims new entry Notable late-month consulting + finance hits.	08

► BEHAVIORAL SIGNALS

DragonForce's rise is the month's most strategically significant shift. Its absorption of former RansomHub affiliates following the latter's April infrastructure takeover positions DragonForce as a candidate for dominant-platform status alongside Qilin and a re-emergent LockBit 5.0. **TheGentlemen** integrated SystemBC for proxy-based payload delivery during April, sophistication suggesting experienced operator backing.

A separate development: a former **BlackCat (ALPHV) negotiator** pleaded guilty in April to charges related to 2023-2025 attacks, exposing internal negotiation data leakage. The case underscores insider risk inside the ransomware economy itself and may yield further attribution leads in coming months.

Notable Attacks, April

April's incident wave was defined by **third-party and supply-chain compromise**. Major brands including Vimeo, ADT, Booking.com, and Vercel were reached not through direct exploitation but via trusted vendors, integrated services, or downstream partners. The pattern signals a shift in attacker economics: compromising a single vendor unlocks dozens of high-value targets simultaneously.

Vimeo (via Anodot)

SUPPLY CHAIN · SHINYHUNTERS · APRIL 2026

Video platform Vimeo confirmed exposure of customer data through a breach of Anodot, a third-party business monitoring service used by Vimeo. ShinyHunters claimed responsibility, releasing technical metadata, video titles, and customer email addresses. The attack demonstrates how observability and analytics integrations, rarely classified as critical attack surface, can act as direct conduits to primary data stores.

ADT Inc.

HOME SECURITY · SHINYHUNTERS · APRIL 20, 2026

ADT confirmed a data breach affecting approximately 5.5 million individuals after ShinyHunters threatened to release stolen data. The breach exposed dates of birth, partial Social Security numbers, and Tax IDs. This is ADT's third disclosed breach since August 2024, raising structural questions about the company's customer data segmentation and identity controls.

Frost Bank

FINANCIAL SERVICES · EVEREST · APRIL 2026

Frost Bank was listed by the Everest ransomware group on multiple ransomware tracking platforms in April. Reports indicate compromise affecting more than 250,000 individuals, with exposed data including Social Security numbers, Tax Identification numbers, W-2 forms, 1099s, mortgage interest records, and ACA reporting documents, a tax-document-heavy dataset suggesting access to the bank's reporting and compliance infrastructure.

Amtrak

TRANSPORTATION · SHINYHUNTERS · APRIL 14, 2026

ShinyHunters claimed theft of approximately 9.4 million Amtrak records, threatening public release unless paid. The data was reportedly exfiltrated through Salesforce integration, the same SaaS pivot pattern observed across multiple ShinyHunters operations in 2026. Amtrak has not publicly confirmed or denied the specific record count, but operations were not disrupted.

Booking.com

TRAVEL PLATFORM · DATA THEFT · APRIL 12, 2026

Booking.com notified customers on April 12 of a breach exposing reservation details including full names, addresses, booking dates, email addresses, phone numbers, and free-text notes left for hotels. The free-text field is particularly sensitive: customers commonly include disability requirements, dietary restrictions, and travel companion data alongside more mundane requests.

Vercel (via Context.ai)

DEVELOPER PLATFORM · SUPPLY CHAIN · APRIL 19, 2026

Vercel detected unauthorized access traced to a compromised third-party tool, Context.ai. Attackers claimed exfiltration of access keys, source code, API credentials, and database data tied to internal deployments. The incident is one of several April compromises traceable to AI-tooling supply chains, an emerging category of trust-by-default integration that few security programs have formally inventoried.

Spotlight: Cisco SD-WAN (ED 26-03)

The vulnerability event of April 2026 was CISA's **Emergency Directive 26-03**, issued April 20, mandating 72-hour federal remediation of three Cisco Catalyst SD-WAN Manager flaws. Two of them, **CVE-2026-20122** and **CVE-2026-20128**, had been confirmed by Cisco as exploited in the wild during March, with one explicitly linked to ransomware operations. The directive marked CISA's most aggressive patching mandate of 2026 to date.

Cisco Catalyst SD-WAN Manager Cluster, ED 26-03

CVE-2026-20122: Incorrect use of privileged APIs · arbitrary file overwrite · vmanage privileges

CVE-2026-20128: Recoverable password storage · local privilege escalation to DCA user

CVE-2026-20133: Sensitive information exposure · remote unauthenticated read

Federal due: April 23, 2026 (72 hours from KEV addition)

Ransomware tag: CVE-2026-20122 and CVE-2026-20128 marked YES in KEV

► WHY AN EMERGENCY DIRECTIVE

Emergency directives are reserved for situations where CISA assesses that a vulnerability presents an immediate, substantial risk to federal networks. The Cisco SD-WAN cluster met that threshold for three reasons: the platform manages tens of thousands of branch-office WAN connections in federal civilian agency networks; the bugs chain naturally (information disclosure into privilege escalation into file overwrite); and the platform's architectural position grants attackers the ability to reconfigure traffic flows across an entire WAN fabric.

► RMM EXPLOITATION CONTINUES: BOMGAR (CVE-2026-1731)

April also saw a renewed wave of exploitation against the BeyondTrust Remote Support (Bomgar) flaw **CVE-2026-1731** originally disclosed in February. Huntress SOC observed an uptick beginning April 3, with threat actors using compromised Bomgar instances to deploy **LockBit ransomware** based on the leaked LockBit 3.0 builder. In one MSP incident on April 15, attackers leveraged a high-privilege Bomgar account to push remote-access tools to the MSP's downstream customer base, converting a single RMM compromise into a multi-org supply-chain attack.

► DISCLOSURE-TO-EXPLOIT TELEMTRY, APRIL

DATE	EVENT
Apr 03, 2026	Huntress SOC observes renewed Bomgar (CVE-2026-1731) exploitation wave
Apr 13, 2026	CISA adds 7 KEV entries including Microsoft Windows, Adobe, Fortinet
Apr 14, 2026	CVE-2026-32201 (Microsoft SharePoint) added to KEV
Apr 15, 2026	MSP-level Bomgar compromise observed; downstream customer environments affected
Apr 17, 2026	SimpleHelp CVE-2024-57726 / 57728 added to KEV (DragonForce ransomware link)
Apr 20, 2026	Emergency Directive 26-03 issued; 8 vulnerabilities added in single batch
Apr 22, 2026	Microsoft Defender CVE-2026-33825 added to KEV

Vulnerability Landscape

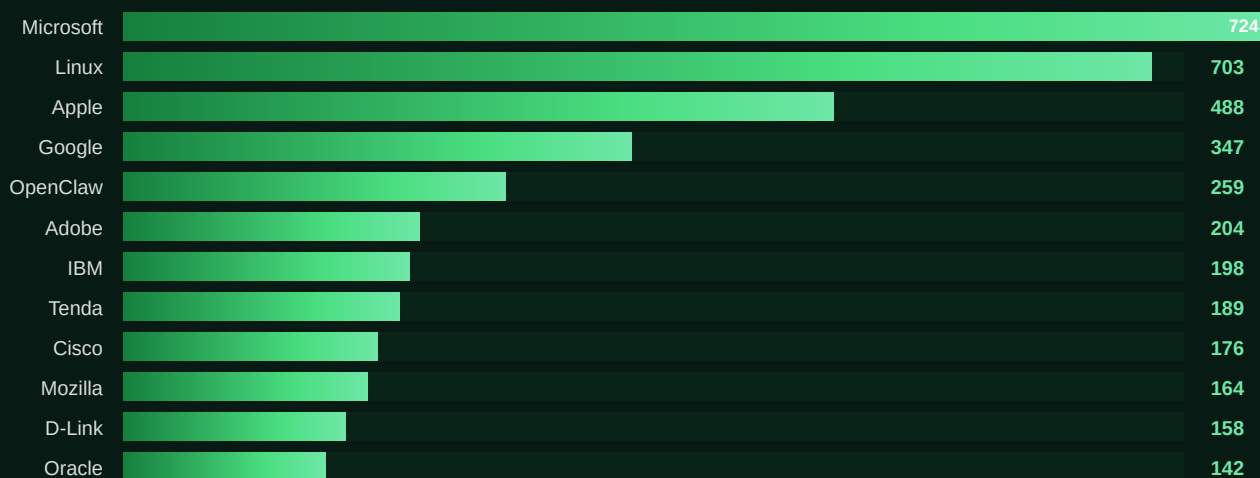
April recorded approximately **5,420 disclosed CVEs**, modestly below March's 5,799 but maintaining the elevated 2026 cadence. More important than raw volume: the rate of confirmed in-the-wild exploitation accelerated, with CISA adding **19 new entries** to the KEV catalog during the month, including the Cisco SD-WAN trio that prompted Emergency Directive 26-03.



Year-to-date disclosure now stands at approximately **20,151 CVEs** through April 30, a 27% increase over the comparable period in 2025. The cumulative trajectory points to roughly 60,000+ CVEs for the full year, a number that fundamentally exceeds the manual-triage capacity of all but the most heavily resourced security programs.

►TOP AFFECTED VENDORS, YTD 2026

Through April 30, Microsoft and Linux remain the top two vendors by disclosed vulnerability count, mirroring their dominant footprint across enterprise environments. Apple, Google, and emerging entrants like OpenClaw round out the top tier. Network-edge vendors, Tenda, D-Link, and similar, continue to attract elevated disclosure activity, reflecting research focus on consumer and small-business perimeter devices.



Top vendors by disclosed vulnerability count, January through April 2026

Recently Exploited

The following entries were added to CISA's Known Exploited Vulnerabilities catalog during April 2026. Each represents confirmed in-the-wild exploitation. Federal civilian agencies are required to remediate by the listed due date; private organizations should treat these as same-week priorities regardless of vendor patch cycle.

CVE ID	VENDOR / PRODUCT	DATE ADDED	DUE	RANSOM?
CVE-2026-41940	WebPros cPanel & WHM / WP2	4/30/2026	5/21/2026	
CVE-2026-33825	Microsoft Defender	4/22/2026	5/13/2026	
CVE-2026-20122	Cisco Catalyst SD-WAN Manager	4/20/2026	4/23/2026	YES
CVE-2026-20128	Cisco Catalyst SD-WAN Manager	4/20/2026	4/23/2026	YES
CVE-2026-20133	Cisco Catalyst SD-WAN Manager	4/20/2026	5/04/2026	
CVE-2025-48700	Synacor Zimbra Collaboration	4/20/2026	5/04/2026	
CVE-2025-32975	Quest KACE SMA	4/20/2026	5/04/2026	
CVE-2025-2749	Kentico Xperience	4/20/2026	5/04/2026	
CVE-2024-27199	JetBrains TeamCity	4/20/2026	5/04/2026	
CVE-2023-27351	PaperCut NG/MF	4/20/2026	5/04/2026	YES
CVE-2026-32201	Microsoft SharePoint Server	4/14/2026	5/05/2026	
CVE-2026-21643	Fortinet (SQL Injection)	4/13/2026	5/04/2026	
CVE-2026-34621	Adobe Acrobat & Reader	4/13/2026	5/04/2026	
CVE-2025-60710	Microsoft Windows (Link Following)	4/13/2026	5/04/2026	
CVE-2024-57726	SimpleHelp	4/17/2026	5/08/2026	YES
CVE-2024-57728	SimpleHelp	4/17/2026	5/08/2026	YES

Selected CISA KEV catalog additions during April 2026

End-of-month surprise: CVE-2026-41940 in cPanel & WHM, added April 30, sits on the management plane of a substantial portion of shared hosting infrastructure. Pre-auth bypass on a hosting control panel translates directly into mass website compromise potential. Hosting providers and MSPs should treat this as the highest-priority remediation entering May.

April Themes

Three structural themes defined April's threat landscape and warrant continued monitoring through Q2 2026.



SUPPLY CHAIN

Vimeo via Anodot, Vercel via Context.ai,
Amtrak via Salesforce, brands reached
through trusted vendors



PURE EXTORTION

ShinyHunters, WorldLeaks, and ClOp
continuing encryption-free data theft
model, backups insufficient



MGMT PLANE RISK

cPanel/WHM, Cisco SD-WAN,
BeyondTrust RMM increasingly targeted
as crown-jewel attack vectors

►THEME 1, THE VENDOR AS INITIAL ACCESS

April's supply-chain incidents share a structural pattern: the primary brand (Vimeo, Vercel, Amtrak, Booking.com) has reasonably mature security; the breach point is a peripheral integration few customers had explicitly inventoried. Anodot is a business-monitoring vendor. Context.ai is a developer productivity tool. Salesforce is the integration platform many of ShinyHunters' targets share. The lesson: third-party integrations now constitute the largest under-managed attack surface for SaaS-first organizations.

►THEME 2, PURE EXTORTION OPERATIONS

A growing share of "ransomware" activity in April involved no encryption at all. Groups including **ShinyHunters** (18 victims in April), WorldLeaks (13), and the continuing ClOp Oracle campaign now operate as data-theft-and-extortion shops exclusively. The shift breaks the backup-as-defense posture that has anchored most ransomware preparedness. Organizations cannot restore stolen data; the threat lever is reputational and regulatory rather than operational.

►THEME 3, MANAGEMENT PLANE AS CROWN JEWEL

The April KEV cluster, Cisco SD-WAN Manager (3 entries), cPanel/WHM, Microsoft Defender, JetBrains TeamCity, BeyondTrust RMM uptick, points to a unifying attacker preference: control planes and orchestration interfaces. These systems sit above thousands of downstream resources, and a single compromise grants access to everything they manage. CISA's Emergency Directive 26-03 reflects this reality at policy level. Defender programs that still treat management interfaces as "internal" should reclassify them as crown-jewel external attack surface.

Operational read: These three themes converge on a single defensive priority, the systems that provide privileged operational reach (RMM, control panels, orchestration platforms, third-party integrations) are now the highest-value targets. Programs should map these systems explicitly and treat them with the same scrutiny as domain controllers.

Conclusion

April 2026 closed the first third of the year with a clearer picture of where the threat landscape is settling. The headline volume drop from March's 808 to April's 772 should not be read as relief, every month of 2026 has now exceeded any single 2025 month, and the cumulative **2,937 victims** through April annualizes to roughly **8,800 for the year**, well above 2025's 7,308 record.

Three structural conclusions emerge from the month's data. First, the operator ecosystem is fragmenting and growing simultaneously, 70 active groups in April, up from 58 in January. The hoped-for consolidation around a few dominant platforms has not materialized; instead, smaller groups continue to capture share without diminishing the leaders. Second, sector targeting is rotating faster than ever, with healthcare reclaiming the top position in April after manufacturing held it for three months. Third, the geographic broadening, particularly into Germany, Canada, and Western Europe, confirms that opportunistic targeting now substantially outweighs strategic country preferences.

►RECOMMENDED ACTIONS FOR Q2 2026

- **Third-party inventory and access reduction.** April's supply-chain wave (Vimeo/Anodot, Vercel/Context.ai, Amtrak/Salesforce) makes vendor risk inventory non-negotiable. Map every integration with read or write access to production data, validate scope, and revoke unused tokens.
- **Cisco SD-WAN remediation now.** Organizations operating affected versions should treat ED 26-03's federal deadlines as their internal benchmark. The three Cisco CVEs chain into full WAN fabric compromise.
- **Bomgar / RMM forensics retrospective.** Customers who patched CVE-2026-1731 in February should still hunt April-period IOCs, renamed SimpleHelp binaries, unauthorized Domain Admin additions, suspicious bomgar-scc.exe child processes, given the renewed exploitation wave from April 3 onward.
- **Identity and credential resilience.** The 2026 attack chain still begins with stolen credentials in 80%+ of cases. Continuous infostealer monitoring, mandatory MFA on privileged accounts, and aggressive session expiration remain the highest-leverage controls.
- **Data-extortion preparedness.** Pure-extortion operations, CIOp, ShinyHunters, WorldLeaks, render backup-only strategies inadequate. Build classification-based protection for sensitive data, and rehearse regulatory and reputational response playbooks alongside technical recovery.
- **KEV automation.** CISA's catalog absorbed 19 entries in April alone. Manual review of each is no longer viable for resource-constrained programs. Automate ingestion, exposure validation, and ticketing against KEV updates.

The Misbar Team continues to track these developments in real time. April's signals, supply-chain dependency, RMM exploitation resurgence, pure-extortion growth, management-plane targeting, point toward a Q2 in which sophistication compounds at every layer of the kill chain. Programs that treat 2026 as "more of the same" will fall behind. Those that adapt will hold the line.

END OF REPORT, APRIL 2026